



eCitadel Practice Round
Windows Server 2016
Answer Key

Welcome to the eCitadel Practice Round! This document will provide you with information on how to solve the vulnerabilities on a Windows Server 2016 operating system. The goal of the practice round is to give beginners a chance to familiarize themselves with the competition structure.

The vulnerabilities in this image are some of the most basic ones found during an eCitadel competition. Even if you do very well with these vulnerabilities, you will experience greater difficulty with the actual competition.

Below are the answers to the problems that are being scored in this image. Each one includes information on how the problem was found (if applicable), how it was solved, and why it is important from a cybersecurity standpoint.

It is also possible to lose points during the competition. Simple penalties that may arise are noted below the answers. There are many ways to solve some of the problems below. This answer key just shows one method in each case.

One way that you can launch several useful utilities that we will use is the Windows Run menu. To access this menu, you will right click the Start icon in the bottom left  and select Run to open the Run dialog. You will then enter in the necessary program name, and select OK to open it.

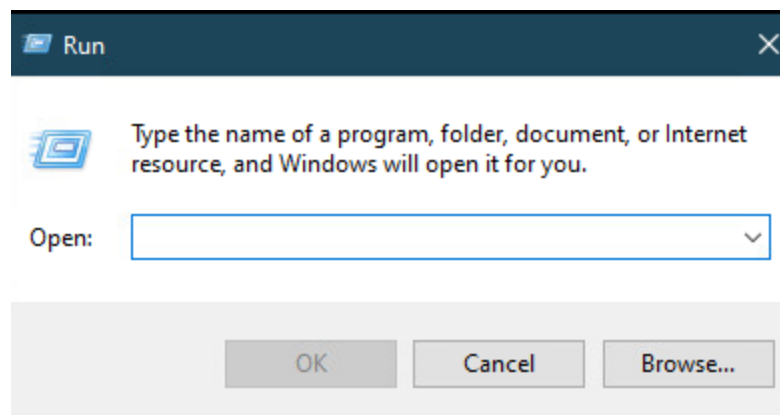


Figure 1 – Windows Run Menu

Answers

1) Forensics Question 1 Correct: 10 pts.

- How do I find this problem?

When you open an image, please read all the "Forensics Questions" thoroughly before modifying the image as you may change something that prevents you from answering the question correctly. There is a file on the Desktop here named "Forensics Question 1".

- How do I solve this problem?

This question asks for the two CNAME aliases that point to the DNS entry "mira.crewmate.local".

Right click the Start icon in the bottom left  and select Run to open the Run dialog. In the Run dialog type **dnsmgmt.msc** and press **Enter** to open DNS Manager. Click **DNS -> polus.crewmate.local -> Forward Lookup Zones** on left side of DNS Manager. Double-click on **crewmate.local** to open our lookup zone for the DNS records.

The answers to the question are the two names with the type **CNAME** and data **mira.crewmate.local**. Remember to **Save** and close the file.

- Why is fixing this problem important?

When managing a DNS server, it is important to know how to manage DNS records for the domain. Malicious or incorrect DNS records can lead to more advanced phishing attacks. Please explore the DNS Manager to find potential places where misconfigurations could take place and result in a more vulnerable server.

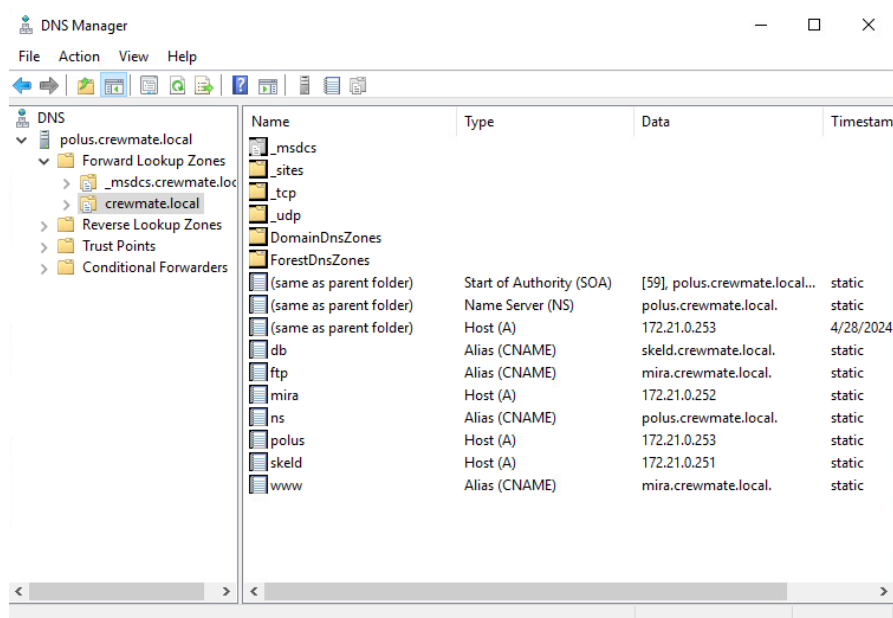


Figure 1 - DNS Manager Displaying records

2) Removed unauthorized users **tan** and **coral**: 4 pts each for a total of 8.

- How do I find this problem?

One of the first things you should do when starting an image during a competition is check the README file on the desktop. The authorized administrators and users listed in the README are the only users that should exist on the system (aside from legitimate built-in system accounts and those used for services). All unauthorized user accounts should be removed.

- How do I solve this problem?

Right click the Start icon in the bottom left  and select Run to open the Run dialog. In the Run dialog type **dsa.msc** and press **Enter** to open Active Directory Users and Computers. Click **crewmate.local -> Users** on the left side of the window. Right click on **tan** and select **Delete**. In the resulting dialog box click **Yes** to confirm that you want to delete the user. Repeat this process for **coral**.

- Why is fixing this problem important?

Computer access should be limited to just those who need to use it to complete their tasks. By leaving unauthorized user accounts on the image, unauthorized individuals may be able to log on to the domain and make changes that could affect the safety and security of legitimate users. Unauthorized user accounts also give adversaries a greater attack surface.

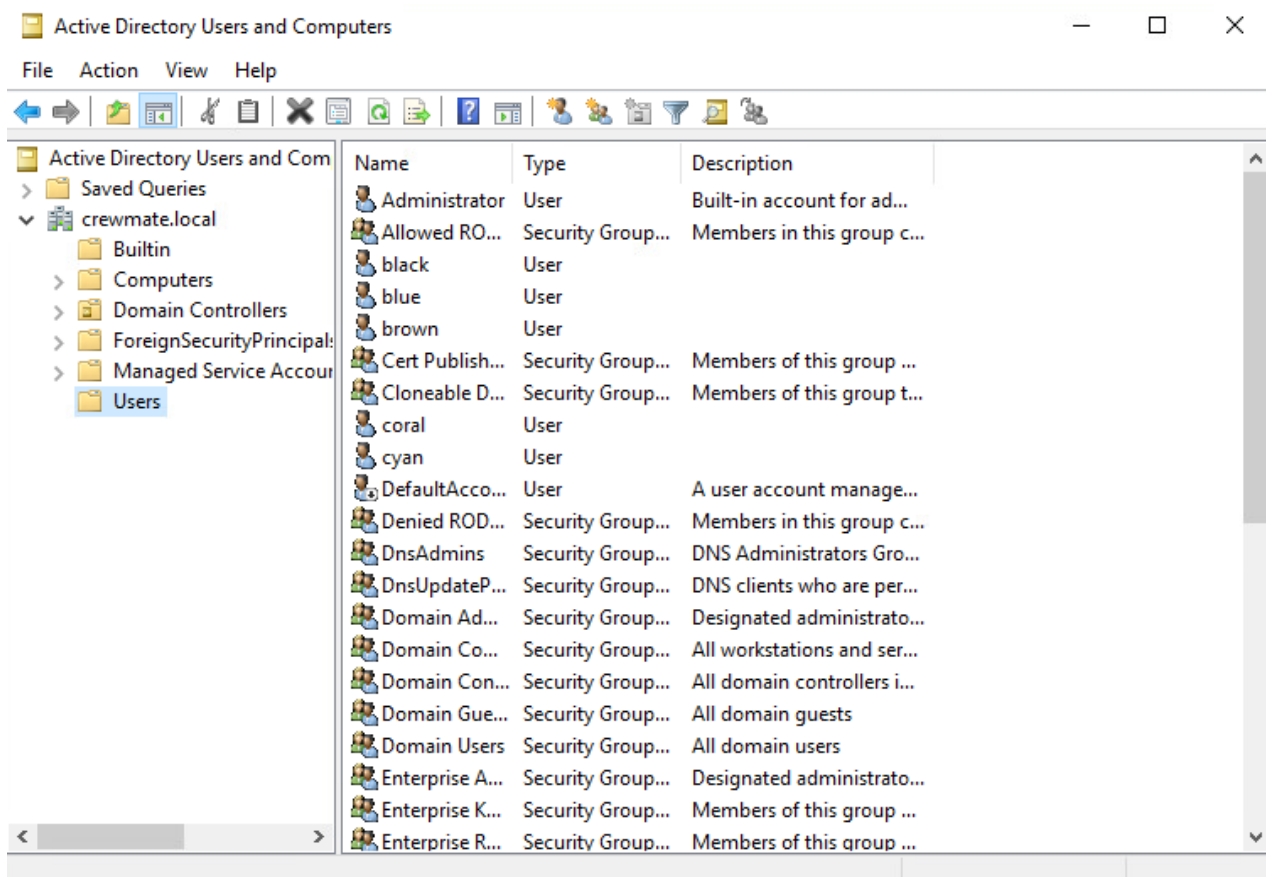


Figure 2 – Active Directory Users and Computers

3) Created domain user account olive: 10 pts.

- How do I find this problem?

Under the inject portal, you have a "New User Inject" that requests a new domain user account to be added to the "crewmate.local" domain.

- How do I solve this problem?

Right click the Start icon in the bottom left  and select Run to open the Run dialog. In the Run dialog type **dsa.msc** and press **Enter** to open Active Directory Users and Computers. Click **crewmate.local -> Users** on the left side of the window. Right click on **Users** and select **New -> User**. Enter in "olive" for **Full name** and **User logon name**, then select **Next >**. Enter in a secure temporary password of your choosing and select **Next >**. Verify the information is correct and select **Finish**.

- Why is fixing this problem important?

Managing the users and computers within a domain is an important skill needed when working with Active Directory. It is recommended that you get familiar with the Active Directory Users and Computer console as several misconfigurations can be found here.

4) User black is not an administrator: 5 pts.

- How do I find this problem?

One of the first things you should do when starting an image during a competition is check the README file on the desktop. The authorized administrators listed in the README are the only users that are authorized have administrator level access. All users not in the list of authorized administrators should have their administrator level access removed.

- How do I solve this problem?

Right click the Start icon in the bottom left  and select Run to open the Run dialog. In the Run dialog type **dsa.msc** and press **Enter** to open Active Directory Users and Computers. Click **crewmate.local -> Built-in** on the left side of the window. Double-click on **Administrators** to open a Properties window. Navigate to the **Members** tab, select **black**, and click **Remove**, then click **OK** to apply the changes and close the Properties window.

- Why is fixing this problem important?

Administrator level access gives individuals the ability to modify critical system files and functions and should be limited to authorized individuals only. The more users with administrator level access, the higher your risk, since compromising an account with administrator level access gives an adversary complete control of the system

5) User lime is not a Domain Admin: 5 pts.

- How do I find this problem?

One of the first things you should do when starting an image during a competition is check the README file on the desktop. The authorized administrators listed in the README are the only users that are authorized have administrator level access. All users not in the list of authorized administrators should have their administrator level access removed.

- How do I solve this problem?

Right click the Start icon in the bottom left  and select Run to open the Run dialog. In the Run dialog type **dsa.msc** and press **Enter** to open Active Directory Users and Computers. Click **crewmate.local -> Users** on the left side of the window. Double-click on **Domain Admins** to open a Properties window. Navigate to the **Members** tab, select **lime**, and click **Remove**, then click **OK** to apply the changes and close the Properties window.

- Why is fixing this problem important?

Administrator level access gives individuals the ability to modify critical system files and functions and should be limited to authorized individuals only. The more users with administrator level access, the higher your risk, since compromising an account with administrator level access gives an adversary complete control of the system.

6) Changed insecure password for blue: 4 pts.

- How do I find this problem?

Ensuring users have strong passwords is an important principle of cybersecurity. As this is a compromised system, it is likely that the attackers have access to the password hashes on the system. Doing an audit of the current passwords would reveal that the Domain User **blue** has the password "blue".

- How do I solve this problem?

Right click the Start icon in the bottom left  and select Run to open the Run dialog. In the Run dialog type **dsa.msc** and press **Enter** to open Active Directory Users and Computers. Click **crewmate.local -> Users** on the left side of the window. Right click on **blue** and select **Reset Password...** Choose a secure password and type it into the **New password** and **Confirm password** text boxes, and click **Ok**.

- Why is fixing this problem important?

A weak password can be easily cracked and then used by adversaries to access any machine on the domain.

7) A secure minimum password age exists: 4 pts.

- How do I find this problem?

Enforcing industry recommended password policies is good cybersecurity practice.

- How do I solve this problem?

Right click the Start icon in the bottom left  and select Run to open the Run dialog. In the Run dialog type **gpmc.msc** and press **Enter** to open the Group Policy Management console for the Domain. Navigate to **Forest: crewmate.local -> Domains -> crewmate.local -> Group Policy Objects**. Right click on **Default Domain Policy** and select **Edit**. Navigate to **Computer Configuration -> Policies -> Windows Settings -> Security Settings -> Account Policies -> Password Policy**. Set **Minimum password age** to **30 days**.

- Why is fixing this problem important?

Setting a minimum password age prevents users from circumventing the password history requirement by preventing them from changing their password over and over again until they are above the threshold.

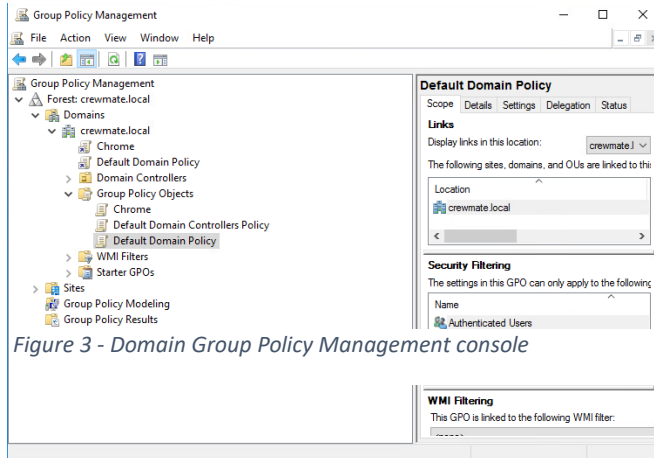


Figure 3 - Domain Group Policy Management console

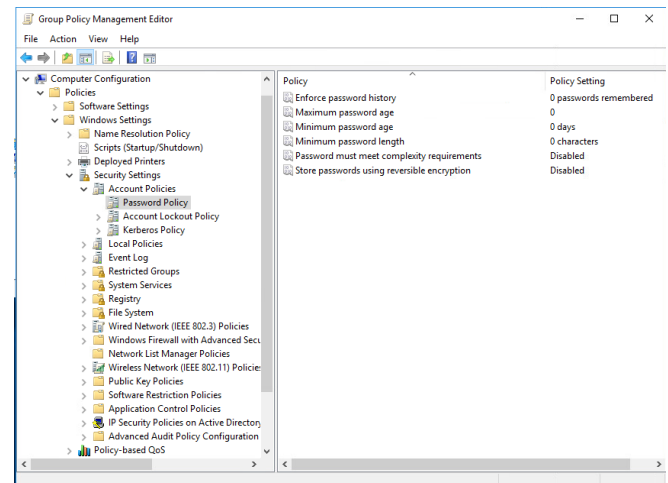


Figure 4 - Domain Group Policy Management Editor

8) A secure lockout threshold exists: 4 pts.

- How do I find this problem?

Enforcing industry recommended account lockout policies is good cybersecurity practice.

- How do I solve this problem?

Right click the Start icon in the bottom left  and select Run to open the Run dialog. In the Run dialog type **gpmmc.msc** and press **Enter** to open the Group Policy Management console for the Domain. Navigate to **Forest: crewmate.local -> Domains -> crewmate.local -> Group Policy Objects**. Right click on **Default Domain Policy** and select **Edit**. Navigate to **Computer Configuration -> Policies -> Windows Settings -> Security Settings -> Account Policies -> Account Lockout Policy**. Double click on **Account lockout threshold**. Set the account lockout threshold to **10 invalid logon attempts**.

- Why is fixing this problem important?

Setting secure account lockout policies limits your risk of having a password compromised. When an adversary performs a brute force attack this will stop or slow down their attack, greatly increasing the time required to compromise a user account.

9) Do not require CTRL+ALT+DEL [disabled]: 5 pts.

- How do I find this problem?

Enforcing industry recommended security options is good cybersecurity practice.

- How do I solve this problem?

Right click the Start icon in the bottom left  and select Run to open the Run dialog. In the Run dialog type **lusrmgr.msc** and press **Enter** to open the Local Security Policy console. Navigate to **Security Settings -> Local Policies -> Security Options**. Double-click on **Interactive Logon: Do not require CTRL+ALT+DEL** to bring up a Properties menu. Select **Disabled** and click **OK** to apply the setting and close the Properties window.

- Why is fixing this problem important?

Not requiring users to press the CTRL+ALT+DELETE key combination leaves them susceptible to malware capturing the user's password. Enforcing this key combination at logon ensures the users are communicating through a trusted path when entering their passwords.

10) Firewall protection has been enabled: 5 pts.

- How do I find this problem?

Enabling a host-based firewall is very important to system security. Windows Defender Firewall is a standard utility that comes installed on all modern Windows operating systems.

- How do I solve this problem?

Right click the Start icon in the bottom left  and select Run to open the Run dialog. In the Run dialog type **wf.msc** and press **Enter** to open Windows Firewall with Advanced Security. Click on **Windows Firewall Properties** in the middle of the window. On all three profile tabs, ensure that Firewall state is set to **On (recommended)**.

- Why is fixing this problem important?

Enabling and properly configuring a firewall is critical to ensuring that you are only allowing known, authorized traffic in and out of your computer. Even though it is not currently being scored, you should audit the allowed traffic rules to ensure that the firewall is in an effective state. Just turning the firewall on is not helpful in the long run.

11) File sharing disabled for C drive: 4 pts.

- How do I find this problem?

It's important to know what files and directories are being shared over the network. As the readme does not state that an SMB file share is required, this machine should not have any unauthorized shares. However, Active Directory creates two shares for functionality and should not be removed: NETLOGON and SYSVOL.

- How do I solve this problem?

Right click the Start icon in the bottom left  and select Run to open the Run dialog. In the Run dialog type **fsmgmt.msc** and press **Enter** to open Shared Folders. Click **Shares** on left side of Shared Folders. Right click on **C** and select **Stop Sharing**. Click **Yes** to confirm that you want to stop sharing the C drive.

- Why is fixing this problem important?

Unauthorized file shares are a security vulnerability. The C\$, ADMIN\$, and IPC\$ shares are default administrative shares created automatically by Windows. **Microsoft does not recommend disabling the administrative shares.**

12) FTP service has been stopped and disabled: 5 pts.

- How do I find this problem?

Stopping and disabling insecure or unnecessary services is an important principle of good cybersecurity. Many services need to be running to ensure normal and secure operation of computer systems. Reading about the services on your system and doing research can help you determine the importance of a service and if it is necessary for normal operation. Additionally, business critical services listed in the README should remain running at all times. The Services management console lists all services, their startup type, and their current status.

- How do I solve this problem?

- Right click the Start icon in the bottom left  and select Run to open the Run dialog. In the Run dialog type **services.msc** and press **Enter** to open Services. Scroll down, and double-click on **Microsoft FTP Service** to open a Properties window. Change the Startup type to **Disabled** to prevent the service from starting automatically, then click **Stop** to stop the service. Click **OK** to apply the changes and close the Properties window.

- Why is fixing this problem important?

Disabling unnecessary services can limit your attack surface. The less services an adversary has to attack and potentially exploit, the lower your risk. Adversaries may attack known or unknown vulnerabilities in services to obtain information, escalate privileges, or gain unauthorized access.

13) Windows automatically checks for updates: 4 pts.

- How do I find this problem?

Updating your operating system is an important principle of good cybersecurity. Automatic updates allows system administrators to ensure that Windows stays up to date.

NOTE: Installing Windows Updates is not a scored task. You are not required to install Windows Operating System updates.

- How do I solve this problem?

Right click the Start icon in the bottom left  and select Run to open the Run dialog. In the Run dialog type **gpedit.msc** and press **Enter** to open the Local Group Policy Editor console. Navigate to

Computer Configuration -> Administrative Templates -> Windows Components -> Windows Updates. Double click on **Configure Automatic Updates**. Enable the setting, selecting **4 – Auto download and schedule the install**. Also, check the box for **Install updates for other Microsoft products**.

- Why is fixing this problem important?

When security vulnerabilities are found in software, the software vendor publishes updates that patch the security vulnerabilities. Adversaries can more easily compromise your system if software is present that has known security vulnerabilities. Ensuring software is up to date removes known security vulnerabilities.

14) Google Chrome has been updated: 4 pts.

- How do I find this problem?

Updating installed applications and services to fix security vulnerabilities is an important principle of good cybersecurity.

- How do I solve this problem?

Open Google Chrome and navigate to "https://google.com/chrome/". Click on the Download Chrome button to download the latest installer and run it.

- Why is fixing this problem important?

When security vulnerabilities are found in software, the software vendor publishes updates that patch the security vulnerabilities. Adversaries can more easily compromise your system if software is present that has known security vulnerabilities. Ensuring software is up to date removes known security vulnerabilities.

15) Removed plain text file with passwords in it: 5 pts.

- How do I find this problem?

Sometimes employees may be storing sensitive information in a way that violates standard policies. Auditing the user home directories reveals a file with all domain account passwords.

- How do I solve this problem?

In **file explorer**, navigate to **C:\Users\cyan\Documents**. Inside this directory is a document called "users.csv" which contains a CSV (Comma-Separated Values) with usernames and passwords. Right click the file, and select **Delete** to remove it.

- Why is fixing this problem important?

Storing plain-text credentials on this machine leaks users' passwords and could potentially lead to further breaching elsewhere.

16) Removed CCleaner: 3 pts.

- How do I find this problem?

Removing unauthorized and potentially unwanted programs from a computer is an important cybersecurity principle. Third party software installed on the system should be limited to the software listed in the README, and software required for normal operation of the operating system, and services and software listed in the README.

- How do I solve this problem?

On the desktop for the user cyan, right click and **delete** the executable icon **CCleaner**. NOTE: As this icon does not contain the shortcut icon , we know that this is the executable itself. Attempting to delete a shortcut will leave the executable software on the machine anyways.

- Why is fixing this problem important?

Removing unauthorized software from your system is important for limiting your risk and reducing your attack surface. Unauthorized programs may leak confidential information, interfere with business critical software and services, contain various malware, contain security vulnerabilities, or could introduce unwanted legal and regulatory issues.

17) Removed netcat backdoor: 6 pts.

- How do I find this problem?

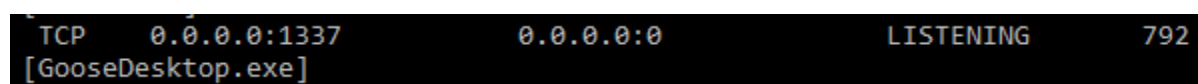
You should always audit systems for indicators of compromise to detect any potential malware running on the machine. A skill needed to detect malware on a machine is the ability to determine abnormalities. Attackers work their hardest to prevent detection and increasingly try to mask their actions as legitimate. Utilizing the netstat command in an Administrative command prompt **netstat -abonp TCP** will show us all **LISTENING** and **ESTABLISHED** TCP connections, as well as the PID and process associated with them. Looking closely, you can see an executable listening on the port **1337** named "GooseDesktop.exe". Both an abnormal port (representing leet code) and an abnormal process (Goose Desktop should NOT be listening for active connections) demonstrates a process that should be removed. Sysinternals tools are great for detecting abnormal processes, most specifically ProcExp, AutoRuns, and TCPView. Try out autoruns to determine how this process was created when the system booted.

- How do I solve this problem?

Right click the task bar and select **Task Manager**. Click on **More details** to expand the window, and navigate to the **Details** tab. Search for the entry **GooseDesktop.exe** and right click and **select Open file location**. Kill the process in task manager (right click and **End task** in Task Manager) and then delete the executable (right click and **Delete** in file explorer).

- Why is fixing this problem important?

This backdoor allows further access to an attacker at a later date. An attacker can use netcat to connect to the machine on port 1337 to gain command line system access on this machine.



TCP	0.0.0.0:1337	0.0.0.0:0	LISTENING	792
[GooseDesktop.exe]				

Figure 5 - Netstat output containing netcat backdoor

18) Chrome blocks intrusive ads: 4 pts.

- How do I find this problem?

Google Chrome is listed as the primary browser in the README. As such, the security settings within the browser should be configured. While you can configure these settings on a per user basis, it is recommended that Google's enterprise group policy templates be used to enforce these settings on all users.

- How do I solve this problem?

Open Google Chrome and navigate to "chrome://settings/content/ads". Select **Block ads on sites that show intrusive or misleading ads**.

- Why is fixing this problem important?

Allowing intrusive or misleading ads could lead to a user clicking on a malicious link and lead to a future breach.

19) RDP network level authentication enabled: 5 pts.

- How do I find this problem?

Remote Desktop Protocol (RDP) is listed in the README as a critical service. Its important to research how to secure critical services without breaking the required functionality of the service.

- How do I solve this problem?

Right click the Start icon in the bottom left  and select Run to open the Run dialog. In the Run dialog type **systempropertiesremote.exe** and press **Enter** to open the Remote window in System Properties. Check the box for **Allow connections only from computers running Remote Desktop with Network Level Authentication (recommended)**.

- Why is fixing this problem important?

Network level authentication (NLA) adds another layer of authentication before a remote desktop session is established.

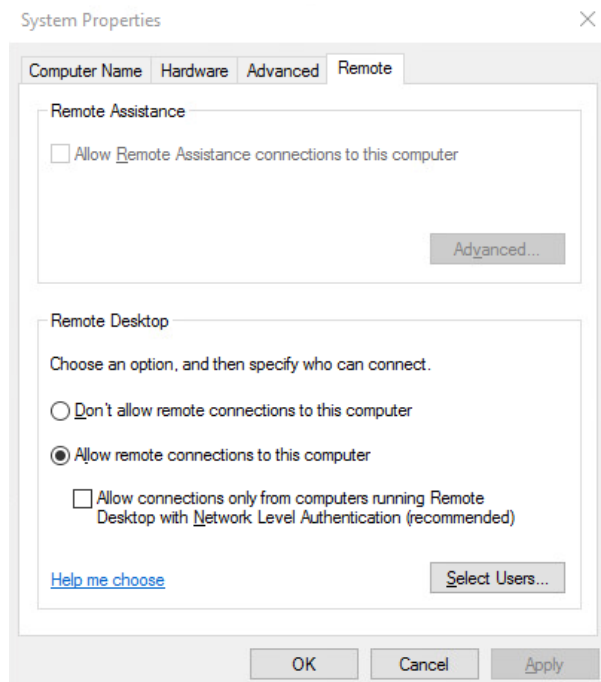


Figure 6 - System Properties window

Penalties

1) Account lockout policy less than 5 is deprecated: -4 pts.

- Why is this a penalty?

Setting the account lockout threshold is an important security precaution to prevent brute force password cracking. The threshold should be set between 5 and 50 failed logon attempts. A threshold of under 5 is too few and may result in valid users accidentally locking themselves out of their accounts, or adversaries easily being able to perform a denial-of-service attack and locking users out of their accounts.

2) Remote Desktop is disabled: -5 pts.

- Why is this a penalty?

The README states that Remote Desktop is a critical service.

3) DNS service is stopped or disabled: -5 pts.

- Why is this a penalty?

The README states that DNS is a critical service.

4) SMB client service (v2/v3) disabled: -5 pts.

- Why is this a penalty?

SMB Client service is critical for Active Directory functionality.

5) File sharing disabled for SYSVOL or NETLOGON directory: -5 pts each.

- Why is this a penalty?

Both file shares are critical for Active Directory functionality.

6) DNS service is stopped or disabled: -5 pts.

- Why is this a penalty?

The README states that DNS is a critical service.

7) Google Chrome is not installed at the default location: -5 pts.

- Why is this a penalty?

The README states that Google Chrome is required software.